

NexaCore IAM Governance & Access Review Assessment

Executive Summary

What Was Assessed:

Identity and access governance across NexaCore's core applications, including:

- Access authorization
- Least privilege
- Identity lifecycle management
- Privileged access
- Service accounts
- MFA enforcement
- Periodic access reviews

The assessment was performed ahead of an internal compliance review.

Why the Assessment Was Conducted

The objective was to provide management with an evidence-based view of whether access is:

- Authorized
- Appropriate for the user's role
- Consistent with least-privilege principles
- Periodically reviewed
- Removed when no longer required

What Was Found

Six core control objectives were tested.

- **0** were rated Fully Effective
- **0** were rated Fully Absent
- **4** were rated Partially Effective
- **2** were rated Ineffective

Seven findings were developed:

- **3 High-risk findings**
- **4 Medium-risk findings**

- **0 Critical findings**

The results indicate that NexaCore has a basic IAM governance structure in place, but control execution is inconsistent in several important areas.

Overall Risk

Overall IAM Risk Rating: Moderate

The identified gaps primarily reflect inconsistent execution of reasonably well-designed controls rather than the absence of an IAM governance program.

This suggests that NexaCore's immediate priority should be improving control execution, evidence, monitoring, and automation rather than rebuilding the entire governance framework.

Highest-Priority Issues

Two identities were identified with active access despite their employment or engagement having ended:

1. One terminated employee retained active access.
2. One contractor whose engagement had ended retained active access.

In addition, one privileged **Security Administrator** account lacked both:

- MFA enforcement
- A current access review

These represent the highest-priority open IAM issues because they combine excessive or unnecessary access with elevated privileges or lifecycle-control failures.

Recommended Next Steps

1. Execute Corrective Actions

Complete the seven corrective actions documented in the CAPA tracker, with immediate priority given to:

- **FND-F2**
- **FND-F5**

2. Automate Deprovisioning

Approve funding and implementation of an automated **HR-to-IAM deprovisioning trigger**.

This should address the underlying lifecycle-control weakness contributing to multiple findings rather than relying solely on manual termination processes.

3. Continue IAM Governance

Maintain the governance program established on Day 6, including:

- Defined RACI ownership
- Review cadence

- KPI/KRI monitoring
- Management reporting
- Periodic control effectiveness reviews

The goal should be to move from reactive remediation toward continuous IAM governance and monitoring.

Management Takeaway

NexaCore does not appear to have a fundamentally broken IAM governance program. The primary concern is **inconsistent execution of existing controls**.

Management should therefore prioritize remediation of termination access, privileged-account MFA, and recurring access-review weaknesses while strengthening automation and ongoing governance monitoring.